



AmeraKey®

Introducing True IoT Security

Table of Contents

IoT Security	3
Encryption	3
Where is the Friction?	6
AmeraKey® Solution.....	6
Authentication.....	7
Where is the Friction?	8
AmeraKey® Solution.....	8
Authorization.....	10
Where is the Friction?	10
AmeraKey® Solution.....	10
Digital Signatures	11
Where is the Friction?	11
AmeraKey® Solution.....	11
Account Management	11
Audit.....	12
Smart Home Hub Example	12
Summary	15

IoT Security

According to Fortune Business Insights, the market for IoT devices will approach \$2T by 2028, with 50B devices deployed and generating 73ZB (Zettabytes - 10^{21} bytes) worth of data. That's a lot of devices and data. According to Palo Alto Networks, 57% of IoT devices are subject to medium to high severity of hacking attacks and 98% of IoT traffic is unencrypted. That's a lot of risk.

Because IoT devices exist at the edge of a network, they pose a dual threat. The first threat is to the operation of the device itself. For example, take a security camera. Its main purpose is outward looking to identify and capture external physical activities. However, that same camera can be hacked and turned into a spy camera exposing internal activities. The second threat is to the network on which the IoT device resides. In this case, the camera acts as a vector into the network from which malware is injected to compromise servers, home computers, etc. to steal data and create or modify the operation of other devices and infrastructure.

Security in IoT devices and computing platforms is thus paramount. Most people think of security as encryption, but it is more than that. Security consists of encryption, authentication (is the User who he says he is), authorization (is the User permitted to perform certain actions), account management (can the User manage which devices and Users are allowed on the network), and audit (the ability to trace back what happened in a session). These last four are commonly known as the four A's of a secure system.

Amera® provides a User friendly, frictionless, low cost, and highly secure methodology for generating and distributing symmetric encryption keys and authentication codes through its **AmeraKey®** technology. **AmeraKey®** is a unique patented technology (14 US granted patents) that solves the problem of distributing symmetric keys to remote Users and eliminates encryption keys based on insecure passwords.

AmeraKey® relies on familiar User activities such as selecting and sending a picture and entering a PIN (which Users already do with banks, ATMs, and other applications). Selecting the picture and PIN is done only one time (during initial provisioning) and thereafter **AmeraKey®** delivers thousands of User authentication codes and device authentication codes, allows authentication to change on the fly and completely does away with passwords. **AmeraKey®** eliminates third party authorizations and Token injection, does away with digital certificates and provides quantum proof encryption of a signed document. With applications in enterprise, data collaboration (including file transfers and storage), communications (including video conferencing, text messaging and email), secure document signing and IoT, **AmeraKey®** is the premier solution for providing true frictionless IoT security.

Encryption

There are two basic methodologies for encryption: symmetric encryption and asymmetric encryption. The most secure level of encryption is the one-time pad which is what symmetric encryption tries to emulate. Symmetric encryption's security lies in the fact that only the sender and receiver possess the encryption keys, the keys are not exposed to the outside world and the keys are not derivable. Also, symmetric keys are typically shorter, thus allowing large files to be encrypted with less computing time and compute resources. However, the drawback is how to distribute the keys remotely.

Asymmetric encryption relies on a scheme of public and private keys. The public key is a mathematical derivation of the private key such that a public key can encrypt while only a private key can decrypt. This solves the issue of key sharing as person A would encrypt a message with person B's public key, and only person B can decrypt it with his private key. The public key is shared to everyone, while the private keys are never shared solving the problem presented by symmetric encryption. However, the penalty for this is that the keys are longer making the process computationally intensive and not suitable for large files. In addition, there are some severe vulnerabilities in asymmetric encryption that call into question whether it can be used in an IoT environment. According to a study by [Keyfactor](#) approximately (0.5%) of the public key certificates they analyzed were vulnerable to attack. While that doesn't sound like a lot, in the IoT world of 2028, that amounts to 250,000,000 devices.

Symmetric encryption and asymmetric encryption also differ in their ability to withstand attacks from quantum computers. In an article on asymmetric encryption by EETimes ([Quantum Computing is a Challenge for Cryptography By Maurizio Di Paolo Emilio 10.02.2020](#)),

"The RSA and ECC algorithms are practically impossible to decipher with brute force methods on a traditional computer. But they're not impossible to a quantum computer with sufficient stable qubits. Quantum computers can therefore threaten all communications, trade, and finance."

Thus, asymmetric encryption is not quantum proof. However, symmetric encryption has been deemed to be quantum proof. According to an ETSI (European Telecommunications Standards Institute) white paper on [quantum safe cryptography and security](#) – page 13:



Figure 1 - Hybrid Encryption

“*Symmetric key ciphers like AES are believed to be quantum-safe, whereas many public key ciphers like RSA are known not to be. A protocol that relies exclusively on ciphers like RSA is vulnerable to quantum attack, but a protocol that can adapt to use quantum-safe ciphers is itself considered quantum-safe. In protocols and applications where public key cryptography is preferred over symmetric-key cryptography (usually, to overcome the difficulty of key distribution and key management problems), quantum safe cryptographic ciphers must be substituted in place of RSA or ECC to resist quantum attack*.” Because of the traditional issues of symmetric key management, a hybrid approach is often used whereby a symmetric key is encrypted using an asymmetric key and then transmitted. However, in the quantum world, asymmetric keys such as RSA can be broken, thus revealing the symmetric key used to encrypt the actual data.

To take advantage of the quantum proof nature of symmetric encryption and to solve the problem of key sharing presented by symmetric encryption, **Amera®** has developed a patented approach to symmetric key generation called **AmeraKey®**. **AmeraKey®** is a source of true randomness which provides the entropy necessary to generate high quality encryption keys used by symmetric algorithms such as AES.

Like any true random number generator (TRNG), **AmeraKey®** extraction, takes a snapshot of a natural phenomenon, in this case noise in a digital image. To distill the entropy from the noise in an image, the harvesting looks at only low-order bits, with a default of 4 low-order bits from different pixels/colors being exclusive-OR 'ed to produce one bit of key data. This isolates the inherent noise from the subject and the camera from the ordered signal of the photograph and concentrates the low-level noise. The pixels being sampled are randomized by a shuffling process driven by picture data itself and a hash of the User-selected PIN. This disperses any local trend to similar pixels.

This extraction distills and concentrates the entropy in a way suitable for an RNG. This technique of concentrating entropy is common for natural sources of entropy where the raw source data is dispersed.

Any image contains a finite quantity of original noise or entropy. The extraction or distillation process accesses pixels in a sequence based on an internal pixel driven shuffling algorithm and a hash pattern from User input, and then munges bits from those pixels in such way to concentrate the entropy. The extraction process does not allow pixels to be sampled more than once.

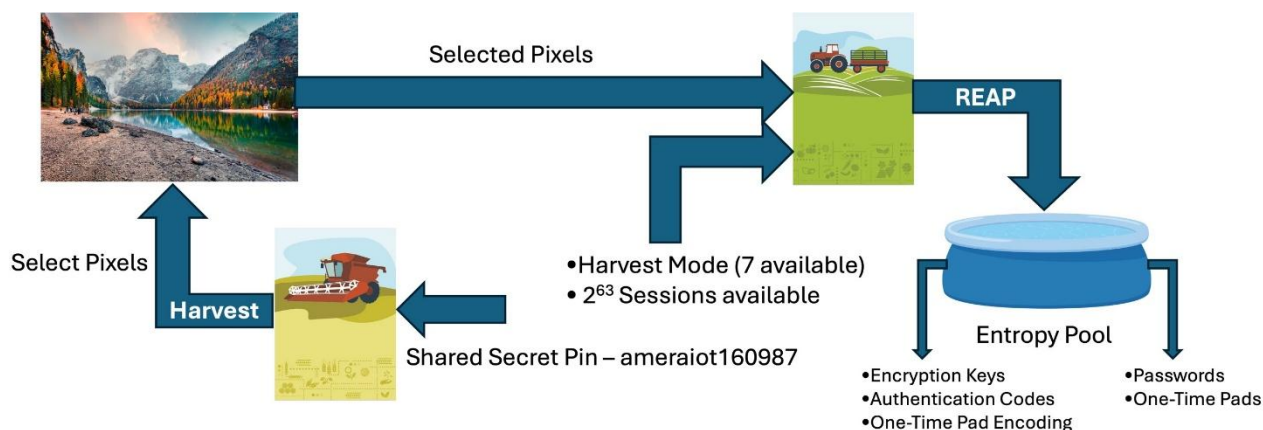


Figure 2 – AmeraKey®

Where is the Friction?

In typical symmetric encryption applications, the friction lies with the key exchange. In the past, this was done in person, a technique that doesn't work well for remote applications. A work around is key generation using a password. This also doesn't work because of the well-known issues with passwords: weak passwords, re-used passwords, shared passwords, too many passwords to remember. These techniques make it extremely difficult to generate a key or change encryption keys at all, let alone trying to change keys on the fly.

AmeraKey® Solution

Amera®'s solution to key sharing friction is for Users to simply share a picture and a PIN number. From those parameters, each User can independently generate thousands of high entropy encryption keys. Through the sharing of an encrypted token, they can synchronize keys after a data session or even on the

fly during a data session. They can even change pictures and PINs before, after, or during the data session and generate brand-new sets of keys. With this technology, **AmeraKey®** eliminates the friction associated with symmetric key encryption and makes it possible to synchronize randomness across multiple remote locations. Because the keys are generated independently no keys are ever transmitted, so there is nothing for an adversary to steal.



Figure 3 – Key Distribution in an IoT System using AmeraKey®

- ***Amera®** has also developed and patented a unique implementation of a one-time pad. This implementation transmits the distance between the binary representation of characters within a specific entropy pool. The net result of this is that cipher text itself is not sent. The only way to reconstruct the message is to traverse the exact same entropy pool on the other side of the communication channel.

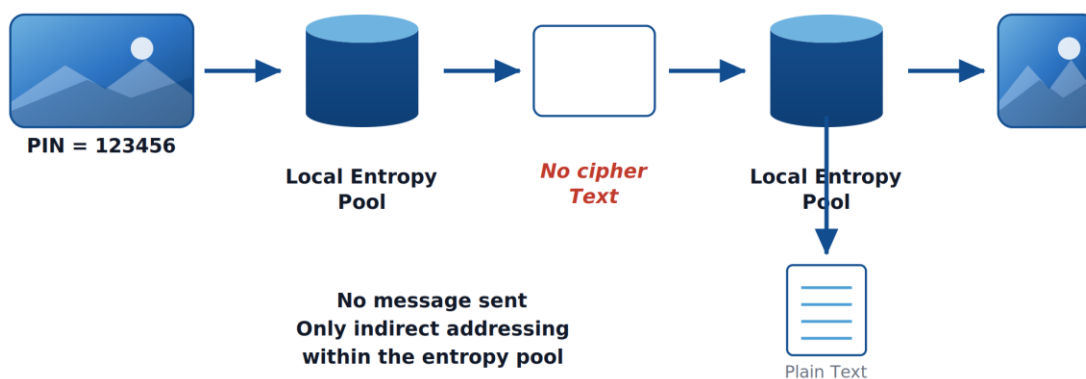


Figure 4 - Amera® OTPE

Authentication

Authentication is the process of verifying a User's identity and their ability to access a requested account. In a secure system, it is critical to know that the User or device requesting access is who or what they claim to be. In the past, this was accomplished using passwords. But as it's been proven time and again, passwords are a terrible way to provide authentication. In a [Harris Poll](#) conducted in partnership with Google the average American has twenty-seven (27) on-line accounts. Forty-three (43) percent of Americans have shared a password, including twenty-three (23) percent who have given someone else their password. Twenty-two (22) percent use their own name as a password for at least one account, seventy-five (75) percent say they have trouble keeping track of all their passwords, and less than half (45 percent) of Americans change their password, even after a data compromise or breach.

Two factor authentication (2FA) was introduced to combat the poor performance of passwords as an authenticator. However, 2FA has already been [compromised](#), and 2FA is difficult to implement in the IoT space. The solution to this is to get rid of passwords altogether.

To eliminate passwords, W3C and the FIDO alliance have created an API called WebAuthn which relies on public key encryption. While the technology works, it is far from frictionless and for the end User any friction translates to confused and angry customers, which translates to call-center cost and customer churn.

Where is the Friction?

First, when an IoT device is received, it needs to be registered on the vendor's IoT server to set up any security. These websites have different paths for their setups, and what the security settings are called and where they are found are inconsistent between websites. Browsers and operating systems have different UI's which can present the experience in a different-looking window, tab, or modal. The terminology is different, inconsistent, and confusing. Even the very few sites that support the full password-less WebAuthn experience need to provide other options, so you need to click on a separate link for the password-less path. And if you make a mistake during setup, the error messages are not helpful.

Second, technologies such as the WebAuthn API relies on certificates and public key asymmetric encryption, both of which have proven vulnerable to attacks and neither of which are quantum proof.

Third, the focus is on User authentication and not necessarily the device authentication. Device identification is generally done using third party servers as authenticators. This is both a security risk as well as an unnecessary step in the process.

Finally, the authentication code is static and cannot be changed unless the User re-registers.

AmeraKey® Solution

First, with the User supplying just a picture and a PIN and utilizing the random bit harvest described above and with different harvest modes and output formats set in firmware, **AmeraKey®** generates thousands of unique authentication codes. An authentication token is passed between an IoT device and a computing platform to synchronize which of the thousands of authentication codes to use. Much like the encryption token, authentication codes can be changed on the fly during or after a data session. This information

exchange is encrypted using **AmeraKey®** encryption technology. No confusing interfaces for the User, just select a picture and enter a PIN number.

Second, this methodology works well with local biometrics to form a complete User authentication mechanism. The biometrics are never transmitted to third-party servers. However, biometrics are not required. The picture a User selects is sufficient for both User authentication and encryption.

Third, as noted earlier, public keys and certificates can be compromised, and they are not quantum proof. Sending authentication codes using **AmeraKey®**'s symmetric key encryption is quantum proof.

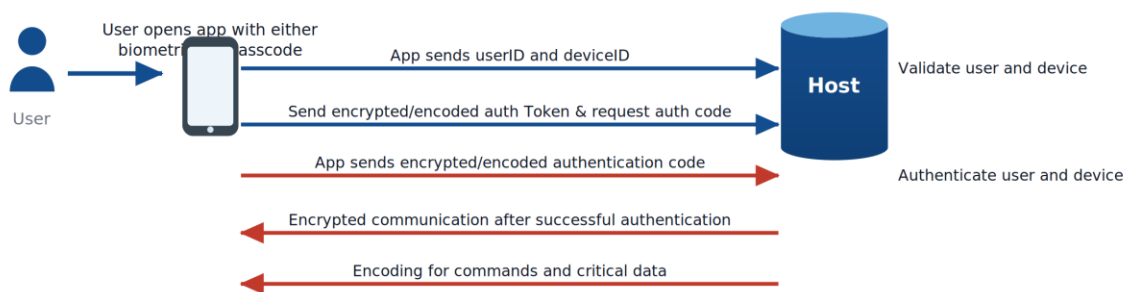


Figure 5 - Amera® Authentication

Fourth, the IoT devices and Users are authenticated separately. Users, Servers and IoT devices must authenticate each to the other prior to any secure transaction to take place. The final piece of the **AmeraKey®** authentication solution is the Session parameter. Within each data session, the encryption token, User authentication code, and IoT device authentication code is permitted to change. A session parameter is assigned to a particular data session. This session parameter is used to generate both encryption keys and authentication codes that are valid for that data session. There is a total of 2^{63} (9 quintillion) possible sessions with each session capable of generating tens of thousands of encryption keys and authentication codes.

All the activity described above happens in the background. The User is only required to select a picture and a PIN at initial registration, making the entire process frictionless. Logins are also frictionless after the initial registration as opening an app on a User device will automatically send the User id, User authentication codes, and session token, so not only is the system password-less, but there is also no need for the User to enter or remember a User ID.

For legacy purposes, passwords can also be generated from the harvest, automatically stored, used, and rotated without User interaction. This eliminates the most common problems with passwords including User friction. The User can also be assured that none of the passwords generated will likely be in any common password dictionary. One interesting thing about passwords. Many companies assume that restricting passwords to a particular length, with upper-case and lower-case letters, combined with numbers and special characters is very secure. That is not the case. What those restrictions do is limit the universe of possible combinations of characters which the password can contain. The only significant condition is the length of the password, and while it is recommended to mix in those other characters,

forcing the password to contain those characters makes it easier for the hacker since he knows that at least one number and one special character must be in the password.

Authorization

Authentication and authorization work hand in hand in secure IoT applications. While authentication proves who you are, authorization establishes what you can and cannot do within the IoT universe, such as enable or disable devices and Users. This provides an extra layer of security since if you can't prove your identity, you won't be allowed into a resource. And even if you can prove your identity, if you are not authorized for that resource, you will still be denied access.

Where is the Friction?

Most of the authorization is performed on the server side of the system, and most of it is one way; is the device authorized to send data, is the User authorized to send a command?

There is a two-way authorization which calls for each device to have a unique digital identity stored for the other device and then compare identities. The devices can only connect when the first device trusts the second device's digital certificate and vice versa. This method relies on the use of digital certificates and can be cumbersome in an IoT environment.

There is also a centralized three-way authorization approach in which an admin registers the devices with a central authority or server and associates the devices with valid digital certificates. As we have seen with digital certificates and public key encryption, they can both be hacked and are not quantum proof. In addition, onboarding and offboarding IoT devices would call for a very robust certificate lifecycle management process.

AmeraKey® Solution

First, using **AmeraKey®**, authorization codes can be provisioned and then embedded within the authentication token and sent over the **AmeraKey®** encrypted link. This eliminates any storing of the actual codes on a server and thus obviates the need for the use of certificates. It also eliminates the use of any third parties within the authorization process as well as eliminating the need for certificate lifecycle management.

Second, since the authorization token is part of the User and server authentication, the receiving server can simultaneously authenticate and authorize.

Third, the **AmeraKey®** integrated approach to security means that all tokens are communicated via **AmeraKey®** encryption making the authorization and authentication process secure and quantum proof.

Digital Signatures

There are times when an additional level of authentication may be required in an IoT environment. Take for example, the case where someone wants to update an IoT device's firmware. This should require additional authorization and may even require that the command be digitally signed.

Where is the Friction?

The primary technologies used in digital signatures are public key encryption and digital certificates. Their objective is twofold: to make sure what is being signed has not been modified, and to authenticate the person who signed. There are two sources of friction here.

First, as we have seen, public key encryption is not quantum proof calling into question not only the authenticity of the command, but also the authenticity of the person signing the command.

Second, digital certificates can and have been compromised not only impacting authenticity, but also exposing User data.

Both issues could have devastating effects.

AmeraKey® Solution

Within **AmeraKey®**, digital signatures may be created with either a biometric input (fingerprint, facial, etc.) or with a PIN. Biometric inputs can utilize **Amera®**'s fingerprint capture or facial recognition, or a device's biometric utilities. From the **AmeraKey®** random harvest engine, a digital signature code is generated. Both the digital signature code and PIN are sent to the server over an **AmeraKey®** encrypted link. The digital signature code may also contain a date stamp and geolocation code for further authenticity.

When something like a command to update needs a signature, it is hashed along with the digital signature code and sent to the receiving party. Since thousands of digital signature codes can be generated, digital signature codes can be rotated out at any time.

Since **AmeraKey®** is a symmetric encryption technology, transactions are quantum proof and there are no certificates to compromise.

Account Management

In a multi-User environment, coupled with defining the right level of access for a User are a range of account management concepts. The principle of least privilege is a guideline that grants a User the least amount of access, permissions and privileges needed. The assignment of privileges needs to be periodically reviewed for misalignment between a User's needs or role, their level of access, and usage to check for changes, privilege creep or the need to deactivate accounts.

Offboarding Users who no longer need access to a system is just as important as following best practices when establishing an account. User rights can also be defined by location or time-of-day that help to prevent unauthorized access outside of defined time or geographic boundaries.

Take for example a consumer level security system. The parents in the home might have privileges to not only enter the arm/disarm codes, but also change them or to have access to the video cameras attached

to the system. Whereas the children might only be able to arm and disarm the system and have no access to the video feeds. Then if the children go off to summer camp, a location-based privilege would disable even the ability to arm or disarm the system. Similarly, a time-based privilege could be set up for the cleaning service such that on a certain day of the week at a certain time, the service could disarm the system, enter, and clean, then leave and arm the system. With our picture and pin technology, all of this is easily handled in the **AmeraKey®** world.

Audit

The final piece of the puzzle is the audit function. **Amera®** API's and SDKs provide an audit function to issue notifications of attempted intrusions and log User access activity. User access activity is particularly important for instance if an employee leaves the company. You would want to be able to trace back what data movement activities and data sharing might have occurred prior to leaving. Alerting the User to this kind of activity is critical so that data is kept private and measures to de-authorize the User can be taken.

Smart Home Hub Example

Smart Home hubs connect devices on a home automation network and control communications between them and/or a cloud server. These hubs were traditionally used as bridges between various protocols, for example from Zigbee, Z-Wave, or BLE to WiFi. This was necessary because some protocols are more power efficient than others and because congestion on the more traditional WiFi or BLE connections can cause performance issues.

The Smart Home hub has evolved to become more of the heart of a smart home network. Hubs now include compute resources to perform some processing tasks before data is forwarded and provide the resources to allow the user to monitor elements of the smart home network and automate, schedule and control tasks. The Hub brings together these various devices and systems into a centralized platform and for users, this simplifies the network by giving them a single application to control the various installed systems and applications. By connecting all the smart home devices to the hub, users can remotely access the various systems and control them with a single smart home app.

With all the smart home devices connected in the home, users can also remotely access the various systems and control them while away from home with their smart home app.

Some typical examples of Smart Home Hubs include Samsung Smart Things, Logitech Harmony Hub, Philips Hue Bridge, Amazon Echo Plus, Google Nest Hub, Apple TV 4K, and Apple Home Kit. With the appropriate software, even something like a Smart TV could act as a Hub.

SmartHome Hub

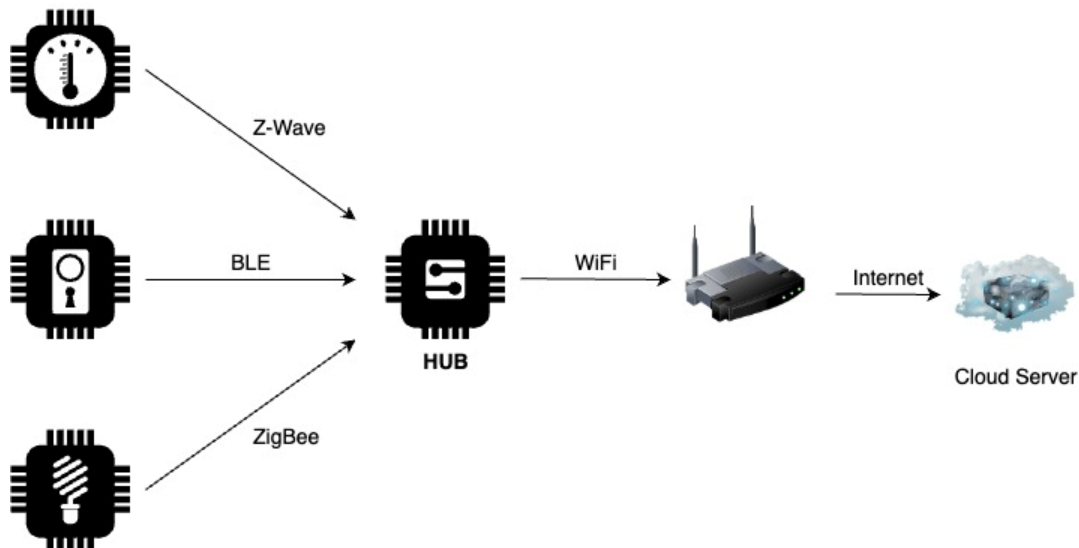


Figure 6 – Typical Smart Home Hub Setup

As convenient as they are, because the Hubs connect to the internet, one of the big issues becomes their security. As noted in a [TechTarget](#) article, there have been several large scale security compromises of Smart Hubs:

- In July 2019, researchers at BlackMarble found an issue with Zipato's ZipaMicro smart hubs where a combination of three security flaws could be exploited to open a smart lock connected to the hub.
- In May 2018, researchers from Pen Test Partners found a five-year-old software flaw in the Z-Wave protocol, dubbed Z-Shave, affecting an estimated 100 million chips in smart home devices sold by more than 2,400 vendors. If attacked, hackers could potentially intercept smart lock keys and unlock home doors.
- In February 2018, researchers at Kaspersky Lab found vulnerabilities in an unnamed smart home hub that could potentially allow remote attackers to access the server and exfiltrate user data, resulting in a potential takeover of the entire smart home system.
- In 2017, Rapid7 researchers found plaintext credentials stored in configuration files in the Android applications used to control the Wink Hub 2 and Insteon Hubs. Unless the phone had strong authentication, full phone encryption or used Android's built-in secure keystores, user data could be lifted from the app.
- In 2016, a Cognosec researcher discovered a flaw in the SmartThings Hub that could potentially allow a robber to break into a smart home by opening smart locks and jamming motion sensors.

SmartHome Hub with **Amera®Key**

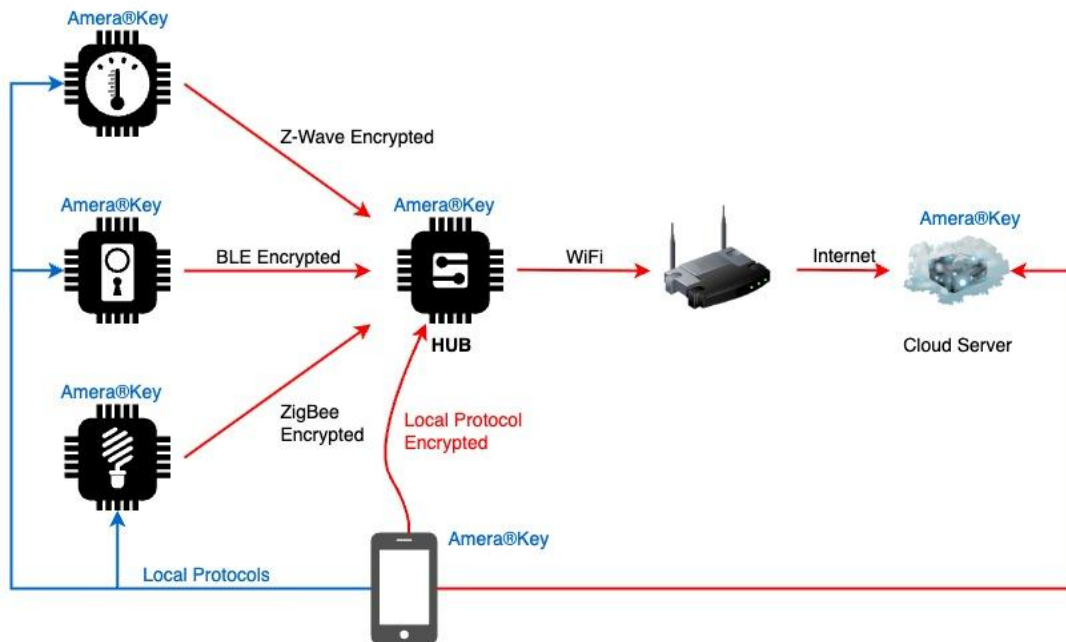


Figure 7 - Smart Home Hub with AmeraKey®

With **AmeraKey®** most if not all the security breaches noted above could be prevented. To start with, a user would locally upload a picture and pin to the Hub. The upload can be done over USB, NFC, BLE, or other local protocol not connected to the internet. This assures the image upload is private. Using the picture and pin upload, a secure link between his device (smartphone for example) and the Hub can be established. Encryption and authentication codes are then generated for that smartphone. After securing the Hub, the user would visit each IoT device, select unique images and pins on his smartphone for each IoT device, and upload those to the IoT device using a local protocol such as USB, NFC, BLE, etc.. He would then upload the images used for each IoT device to the Hub over the secure/authenticated link to the Hub. With these images in place, the Hub can then establish encryption and authentication protocols with each IoT device, and exchange encryption and authentication tokens as needed.

To connect to the cloud server, a User would upload his image to the server and establish an authenticated encrypted channel with the server. The User would then send the Hub image to the server. The server and Hub then set up an authenticated encrypted channel between them and the Hub can then begin to send individual IoT device data to the server. Additional users may be added to the Hub and Cloud Server and authenticated using the same procedures. With this configuration, all data is encrypted, and all devices and users are authenticated, providing an extremely secure home IoT system. An implementation such as this would also work extremely well with proposed private blockchain systems such as the Samsung Knox Matrix.

Summary

We have discussed what functions need to be included in a comprehensive security suite for IoT devices: encryption, authentication, authorization, digital signatures, account management, and audit. We've also shown how **AmeraKey®** technology addresses each of these issues by providing a frictionless, low-cost integrated solution. For encryption, **AmeraKey®** solves the problem of distributing symmetric keys to remote Users and eliminates encryption keys based on insecure passwords. For authentication, **AmeraKey®** uses its random bit harvesting engine to deliver thousands of User authentication codes and device authentication codes, gives the User the ability to change authentication on the fly, and completely does away with passwords. For authorization, **AmeraKey®** does away with third party authorizations and eliminates certificate management. For Digital Signing, **AmeraKey®** does away with digital certificates and provides quantum proof encryption of the signature. **AmeraKey®** is the premier solution to providing true IoT security.